

OWASP Top 10 Vulnerabilities Report

CyberSecurity Internship – VortexTech

Week 1 Assignment

Prepared by: Shahd Mohammed Hosiny Kenawy

Date: July 2026

Table of Contents

1. Introduction	1
2. Broken Access Control (A01)	2
3. Security Misconfiguration (A02)	3
4. Cryptographic Failures (A04)	4
5. Injection (A05)	5
6. Authentication Failures (A07)	6
7. Personal Reflection	7
8. References	8

Introduction

OWASP Top 10 is a list that highlights the most common and critical security risks in web applications. It is created by OWASP, which is a well-known organization in the field of cybersecurity and web security.

The main goal of this report is to understand some of these vulnerabilities in a simple way, explain how attackers can exploit them, and how developers can prevent them. In this report, five vulnerabilities from the OWASP Top 10 list will be discussed with simple explanations, real examples, and prevention methods.

Broken Access Control (A01)

What is it?

This vulnerability happens when a web application does not properly restrict what users are allowed to access. It may allow normal users to view or modify data that belongs to other users or even access admin features.

How attackers exploit it

- Attackers take advantage of weak access control by:
- Changing URLs to access other users' data
- Trying to open admin-only pages directly
- Modifying IDs or parameters in requests to access restricted information

Simple example

For example, if a website uses a link like: `/account? id=10`

an attacker may change the number and access another user's account information.

Prevention

- Ensure users can only access their own data
- Implement proper role-based access control (User / Admin)
- Always check permissions on the server side
- Block unauthorized access by default

Security Misconfiguration (A02)

What is it?

This happens when a system or application is not properly configured, which creates security weaknesses that attackers can easily find and use.

How attackers exploit it

- Attackers can exploit misconfigurations such as:
- Default usernames and passwords (like admin/admin)
- Exposed files or directories
- Unnecessary services running on the system
- Error messages that reveal sensitive information

Simple example

If an admin panel is left open with default login credentials, an attacker can easily log in and control the system.

Prevention

- Change all default settings and passwords
- Disable unused features and services
- Keep systems updated and patched
- Hide detailed error messages from users

Cryptographic Failures (A04)

What is it?

This vulnerability occurs when sensitive data is not properly protected or encrypted, making it easy to steal or expose.

How attackers exploit it

Attackers may:

- Intercept data while it is being transmitted
- Steal unencrypted passwords or personal data
- Break weak encryption methods

Simple example

If a website sends passwords without encryption, attackers can easily capture and read them.

Prevention

- Use strong encryption methods
- Always use HTTPS for secure communication
- Never store passwords in plain text
- Protect data both in transit and at rest

Injection (A05)

What is it?

Injection happens when an attacker is able to send malicious data into an application, and the system treats it as a valid command instead of normal input. This often happens in forms, search boxes, or login pages.

How attackers exploit it

Attackers can:

- Insert malicious code into input fields
- Manipulate database queries
- Bypass login systems
- Access or delete data they should not reach

Simple example

If a login form is not protected, an attacker might enter special input instead of a username or password to trick the system into logging them in without real credentials.

Prevention

- Use prepared statements (parameterized queries)
- Validate all user input
- Avoid direct execution of user input in database queries
- Use security frameworks that handle input safely

Authentication Failures (A07)

What is it?

Authentication Failures happen when a system does not properly verify the identity of users. This allows attackers to guess, steal, or bypass login credentials.

How attackers exploit it

Attackers may:

- Try weak or common passwords
- Use brute force attacks to guess passwords
- Exploit poor session management
- Steal login sessions or tokens

Simple example

If a website allows unlimited login attempts without blocking, an attacker can keep trying different passwords until they successfully log in.

Prevention

- Enforce strong password policies
- Limit login attempts (rate limiting)
- Use multi-factor authentication (MFA)
- Secure session management

Personal Reflection

Working on this report helped me understand how common web security problems can be in real applications. The most interesting part for me was learning how small mistakes, like weak input validation or poor access control, can lead to serious security issues. I also realized how important it is for developers to follow security best practices from the beginning, not after problems happen.

References

- OWASP Top 10 Official Website (owasp.org)
- OWASP documentation and guides
- General cybersecurity learning resources and articles